

Botium Toys Security Audit

Prepared by: Nicolas Montes de Oca

Date: March 2026

Course: Google Cybersecurity Certificate

Controls assessment checklist

Yes	No	Control
	• Least Privilege	Disaster recovery plans
•	• Password policies	
	• Separation of duties	
•	• Firewall	
	• Intrusion detection system (IDS)	
	• Backups	
•	• Antivirus software	
•	• Manual monitoring, maintenance, and intervention for legacy systems	
	• Encryption	
	• Password management system	
•	• Locks (offices, storefront, warehouse)	

- Closed-circuit television (CCTV) surveillance
- Fire detection/prevention (fire alarm, sprinkler system, etc.)

Compliance checklist

Payment Card Industry Data Security Standard (PCI DSS)

Yes	No	Best practice
		• Only authorized users have access to customers' credit card information. • Credit card information is stored, accepted, processed, and transmitted internally, in a secure environment. • Implement data encryption procedures to better secure credit card transaction touchpoints and data. • Adopt secure password management policies.

General Data Protection Regulation (GDPR)

Yes	No	Best practice
		• E.U. customers' data is kept private/secured. • There is a plan in place to notify E.U. customers within 72 hours if their data is compromised/there is a breach. • Ensure data is properly classified and inventoried. • Enforce privacy policies, procedures, and processes to properly document and maintain data.

System and Organizations Controls (SOC type 1, SOC type 2)

Yes	No	Best practice
-----	----	---------------

- | | | |
|---|--|--|
| | | <ul style="list-style-type: none">• User access policies are established.• Sensitive data (PII/SPII) is confidential/private. |
| • | | Data integrity ensures the data is consistent, complete, accurate, and has been validated. |
| • | | Data is available to individuals authorized to access it. |

Recommendations (optional): Botium Toys should consider implementing least privilege access controls and separation of duties as a priority in order to limit the employee's access to sensitive data. The organization should also implement encryption to protect the credit card information of their customers. A stronger password management system with stronger password requirements should also be implemented. The company does not have an Intrusion Detection System (IDS) and should consider implementing one, the establishment of a disaster recovery plan and the backups of data would greatly reduce risk and improve compliance security measures with PCI, GDPR and DSS.